Algoritmi e Protocolli per la Sicurezza

Project Work

WP3: Analisi di sicurezza

Analisi critica del protocollo di voto elettronico proposto nel WP2

Autori: Gennaro Foschillo
Francesco Vittorio Allocca

A.A. 2025–2026

Indice

1 WP3: Analisi di sicurezza **1**

1.1 Obiettivo del Work Package . . . 1
1.2 Metodo di analisi . . . 1
1.3 Assunzioni di sicurezza considerate . . . 1
1.4 Classificazione delle proprietà . . . 2
1.5 Analisi per proprietà . . . 3
1.5.1 Autenticità dell'elettore e del voto . . . 3
1.5.2 Unicità del voto . . . 4
1.5.3 Segretezza della preferenza . . . 4
1.5.4 Pseudoanonimato e separazione delle informazioni . . . 4
1.5.5 Integrità dei messaggi e del registro . . . 5
1.5.6 Verificabilità individuale . . . 5
1.5.7 Verificabilità universale . . . 5
1.5.8 Efficienza . . . 6
1.6 Analisi rispetto agli avversari del modello . . . 6
1.6.1 Elettore malevolo . . . 6
1.6.2 Voting Server malevolo . . . 6
1.6.3 Registro Elettorale malevolo . . . 7
1.6.4 Government Authority malevola o compromessa . . . 7
1.6.5 Scrutiny Authority collusa o compromessa . . . 7
1.6.6 Voting Client compromesso . . . 7
1.6.7 Avversario di rete . . . 8
1.7 Compromessi progettuali . . . 8
1.8 Rischi residui . . . 8
1.9 Possibili estensioni future non adottate . . . 9
1.10 Conclusione dell'analisi . . . 9

1 WP3: Analisi di sicurezza

1.1 Obiettivo del Work Package

Questo Work Package analizza la sicurezza della soluzione proposta nel WP2 rispetto al modello definito nel WP1. L'obiettivo non è dimostrare in modo formale e assoluto la sicurezza del sistema, ma valutare in modo critico quali proprietà risultano supportate dal protocollo, sotto quali assunzioni, e quali rischi residui rimangono.

L'analisi considera il protocollo per un referendum binario, basato sulla separazione tra autenticazione, autorizzazione, raccolta della scheda, registrazione pubblica e scrutinio finale. Le proprietà analizzate sono autenticità, unicità, segretezza del voto, pseudoanonimato, integrità, verificabilità individuale, verificabilità universale ed efficienza.

Nel seguito le proprietà non vengono trattate come tutte garantite allo stesso livello. Alcune sono supportate direttamente dai meccanismi del protocollo, altre sono mitigate solo sotto specifiche assunzioni, mentre alcune rimangono rischi residui o fuori dallo scope della soluzione proposta.

1.2 Metodo di analisi

L'analisi viene svolta confrontando, per ciascuna proprietà di sicurezza:

- l'obiettivo dichiarato nel modello del WP1;
- i meccanismi introdotti nel protocollo del WP2;
- le assunzioni necessarie affinché tali meccanismi siano efficaci;
- gli scenari di attacco che il protocollo mitiga;
- i limiti residui che non vengono eliminati dalla soluzione proposta.

Si assume che le primitive crittografiche utilizzate siano implementate correttamente e che gli algoritmi adottati siano sicuri rispetto ad avversari computazionalmente limitati. In particolare, l'analisi si basa su firme digitali non falsificabili, funzioni hash resistenti alle collisioni, cifratura asimmetrica probabilistica per la scheda, canali sicuri autenticati e strutture Merkle-based per la verificabilità di inclusione.

1.3 Assunzioni di sicurezza considerate

Le proprietà del protocollo dipendono da alcune assunzioni operative e crittografiche. Queste assunzioni non eliminano i rischi, ma delimitano il contesto in cui la soluzione viene valutata.

Assunzione	Descrizione
Primitive crittografiche sicure	Le firme digitali, gli hash, la cifratura probabilistica e i MAC usati nei canali sicuri sono considerati sicuri rispetto ad avversari efficienti.

Assunzione	Descrizione
Corretta gestione delle chiavi	Le chiavi private delle entità infrastrutturali non devono essere divulgate. La compromissione di una chiave privata può invalidare le garanzie associate all'entità corrispondente.
PKI e CRL disponibili	I certificati e le liste di revoca pubblicate dalla Government Authority devono essere recuperabili, firmati e aggiornati. Le entità devono rifiutare certificati scaduti o revocati.
Voting Client non pienamente fidato	Il client può essere compromesso o eseguito su un dispositivo non sicuro. Il protocollo mitiga questo rischio, ma non garantisce pienamente che la preferenza mostrata e quella cifrata coincidano.
Separazione delle responsabilità	La soluzione assume che le entità non colludano tutte tra loro. La separazione tra GA, VS, ER e SA riduce il rischio di associazione identità-voto, ma non elimina il rischio in caso di collusione estesa.
Scrutiny Authority distribuita	Almeno k nodi della Scrutiny Authority devono autorizzare lo scrutinio finale. Questa scelta è una custodia/autorizzazione distribuita dell'uso di sk_{SA}, non una threshold decryption matematica.
Sincronizzazione temporale ragionevole	Timestamp, finestre di validità, CRL e chiusura delle urne richiedono una sincronizzazione temporale sufficiente tra le entità.

1.4 Classificazione delle proprietà

La tabella seguente riassume il livello con cui il protocollo supporta le proprietà dichiarate nel modello. La classificazione distingue tra proprietà supportate direttamente, proprietà mitigate sotto assunzioni e proprietà non pienamente garantite.

Proprietà	Livello	Meccanismi principali	Limite principale
Autenticità	Supportata	Autenticazione presso GA, token firmato, certificati, firma con sk_U	Dipende da GA e dalla protezione di sk_U.
Unicità	Supportata	$IssuedTokensDB$, $SpentTokensDB$, stati *pending*/*committed*	Dipende dalla corretta emissione dei token e dallo stato del VS.
Segretezza	Mitigata	Cifratura probabilistica con pk_{SA}, separazione VS/ER/SA	Non resiste a client compromesso o collusione critica.

Proprietà	Livello	Meccanismi principali	Limite principale
Pseudoanonimato	Mitigato	Separazione identità-token-voto, mancata pubblicazione del token	Possibile correlazione tramite log, timestamp o ordine dei record.
Integrità	Supportata	Firme digitali, MAC/canale sicuro, hash, Merkle Tree	Dipende dalla validità delle chiavi e dalla correttezza del registro.
Verificabilità individuale	Supportata con limite	Ricevuta firmata, $Leaf_i$, $MerklePath_i^{final}$, $Root_{final}$	Verifica l'inclusione, non il fatto che il client abbia cifrato la scelta desiderata.
Verificabilità universale	Supportata se il tally pubblica dati sufficienti	BB_{final}, $Root_{final}$, preferenze decifrate validate, firme SA	Aumenta il rischio residuo di correlazione con metadati esterni.
Efficienza	Vincolo progettuale soddisfatto	Referendum binario, hash, Merkle path logaritmico, chiavi di sessione	Non misura sperimentale in WP3; sarà valutata in WP4.
Coercion-resistance	Non garantita	Ricevuta non contiene la preferenza	Il voto remoto non presidiato resta vulnerabile a coercizione esterna.
Disponibilità	Non garantita crittograficamente	Hard-fail su CRL, separazione dei ruoli	Mancano meccanismi specifici anti-DDoS o di fault tolerance.

1.5 Analisi per proprietà

1.5.1 Autenticità dell'elettore e del voto

L'autenticità richiede che soltanto elettori legittimi possano partecipare alla votazione. Nel protocollo, questa proprietà è supportata dalla separazione tra autenticazione presso la Government Authority e successivo rilascio del token di autorizzazione.

La Government Authority autentica l'elettore e verifica la sua idoneità. Solo in caso di esito positivo viene emesso un $VotingToken_U$, contenente un permesso $Permit_U$ firmato dalla GA. Il token contiene anche pk_U, cioè la chiave pubblica associata all'elettore per la specifica elezione. Durante l'invio della scheda, il Voting Server verifica la firma della GA sul token e la firma σ_U^{Ballot} prodotta con sk_U.

Questa scelta impedisce a un soggetto che possiede solo il token, ma non la chiave privata corrispondente, di usarlo correttamente. La proprietà dipende dalla correttezza della GA, dalla non compromissione di sk_U e dalla corretta verifica dei certificati e delle firme.

1.5.2 Unicità del voto

L'unicità richiede che ciascun elettore possa contribuire al più con una scheda valida al risultato finale. Il protocollo affronta il problema in due punti distinti.

In fase di autorizzazione, la Government Authority aggiorna $IssuedTokensDB$, impedendo l'emissione di più token per lo stesso elettore nella medesima elezione. In fase di raccolta, il Voting Server controlla $SpentTokensDB$, memorizzando un digest non invertibile del numero seriale del token. L'uso degli stati *pending* e *committed* evita che un token venga considerato definitivamente speso prima che il Registro Elettorale abbia confermato la pubblicazione della scheda.

La garanzia ottenuta è quindi: per ogni token validamente emesso, al più una scheda può arrivare allo stato *committed* ed essere associata a un record del Bulletin Board finale. La proprietà non elimina il rischio di comportamento malevolo della GA, che potrebbe emettere token indebiti o duplicati; tale rischio rientra nelle assunzioni di fiducia e va discusso come rischio residuo.

1.5.3 Segretezza della preferenza

La segretezza della preferenza viene garantita principalmente cifrando localmente il voto con la chiave pubblica elettorale della Scrutiny Authority:

$$EncVoto_{SA} = Enc^{prob}_{pk_{SA}}(v).$$

La cifratura deve essere probabilistica, ad esempio tramite RSA-OAEP, perché nel caso di referendum binario una cifratura deterministica produrrebbe lo stesso ciphertext per lo stesso valore di voto. Un osservatore del Bulletin Board potrebbe quindi raggruppare ciphertext uguali e ricavare informazioni statistiche sui voti.

Il Voting Server e il Registro Elettorale non possiedono sk_{SA} e trattano $EncVoto_{SA}$ come oggetto opaco. La segretezza è quindi preservata rispetto a tali entità, sotto l'assunzione che la chiave privata di scrutinio non sia usata prima della chiusura dell'elezione e che la Scrutiny Authority segua la procedura prevista.

La proprietà non è assoluta: un Voting Client compromesso può osservare o alterare la preferenza prima della cifratura; inoltre, una compromissione della chiave privata di scrutinio o una collusione critica nella fase di scrutinio può violare la segretezza.

1.5.4 Pseudoanonimato e separazione delle informazioni

Il protocollo non promette anonimato perfetto, ma mira a garantire pseudoanonimato. L'obiettivo è impedire che una singola entità possa associare direttamente identità reale, autorizzazione al voto e preferenza espressa.

La Government Authority conosce l'identità reale dell'elettore e rilascia il token, ma

non riceve la scheda cifrata. Il Voting Server riceve token e scheda cifrata, ma non dovrebbe conoscere l'identità reale dell'elettore né la preferenza in chiaro. Il Registro Elettorale pubblica record relativi a schede cifrate, senza token e senza identità. La Scrutiny Authority decifra le schede solo dopo la chiusura, ma non riceve informazioni di autenticazione o idoneità.

Rimangono tuttavia rischi residui di correlazione. Un avversario che combini log temporali della Government Authority, del Voting Server e del Registro Elettorale potrebbe tentare di correlare l'ordine di voto con l'identità degli elettori. Il protocollo mitiga tale rischio separando le componenti e non pubblicando i token, ma non introduce meccanismi più avanzati come mixnet o anonimizzazione forte.

1.5.5 Integrità dei messaggi e del registro

L'integrità viene supportata da firme digitali, canali sicuri, hash e struttura Merkle-based. La cifratura della scheda protegge la segretezza, ma non viene considerata sufficiente a garantire integrità. Per questo motivo il protocollo usa firme sui principali oggetti pubblici e messaggi critici.

La Government Authority firma certificati, token, parametri pubblici e CRL. Il Voting Server firma il messaggio inoltrato al Registro Elettorale. Il Registro Elettorale firma ricevute e radice finale. I nodi della Scrutiny Authority firmano le autorizzazioni alla fase di scrutinio.

Il Bulletin Board append-only, organizzato tramite foglie e radice Merkle, rende rilevabili modifiche, rimozioni o sostituzioni dei record dopo la pubblicazione. La sicurezza di questo meccanismo dipende dalla resistenza alle collisioni della funzione hash e dalla corretta pubblicazione della radice finale firmata.

1.5.6 Verificabilità individuale

La verificabilità individuale permette all'elettore di controllare che la propria scheda cifrata sia inclusa nel registro finale. Dopo l'accettazione della scheda, il Registro Elettorale produce una ricevuta contenente $Leaf_i$ e la firma del Registro. Alla chiusura dell'elezione, il Registro pubblica $Root_{final}$ e il relativo $MerklePath_i^{final}$.

L'elettore può quindi verificare che la foglia indicata nella ricevuta appartenga al Merkle Tree finale e che la radice sia firmata dal Registro Elettorale. Questa verifica prova l'inclusione della scheda cifrata, non la correttezza della preferenza cifrata dal client.

Il protocollo supporta quindi una forma di verificabilità individuale di inclusione. Non garantisce pienamente la proprietà di *cast-as-intended* in presenza di Voting Client compromesso.

1.5.7 Verificabilità universale

La verificabilità universale richiede che osservatori esterni possano controllare la coerenza tra record pubblicati, schede scrutinabili e risultato finale. Nel protocollo, un verificatore può controllare BB_{final}, $Root_{final}$, la firma del Registro Elettorale, le autorizzazioni firmate dai nodi della Scrutiny Authority e la coerenza numerica tra schede accettate,

token in stato *committed* e risultato finale.

Per rendere la verificabilità universale effettiva rispetto al conteggio, il $TallyBoard$ dovrebbe pubblicare anche l'elenco delle preferenze decifrate e validate, indicizzate rispetto ai record finali:

$$\{(i, v_i, status_i)\}_{i=1}^{m}.$$

In questo modo, chiunque può ricalcolare:

$$m = count_{\text{Sì}} + count_{\text{No}} + count_{invalid}.$$

Questa scelta rafforza la trasparenza del conteggio, ma introduce un compromesso: la pubblicazione dei valori decifrati associati agli indici dei record può aumentare il rischio residuo di correlazione con metadati temporali o log esterni. Il protocollo accetta questo compromesso per privilegiare la verificabilità universale richiesta dalla traccia.

1.5.8 Efficienza

L'efficienza viene considerata come vincolo progettuale e non solo come metrica sperimentale. Il protocollo adotta un referendum binario, riducendo la complessità della scheda e dello scrutinio. Usa cifratura asimmetrica solo per oggetti piccoli o per proteggere la preferenza verso la Scrutiny Authority, mentre le comunicazioni operative avvengono su canali sicuri basati su chiavi di sessione.

Il controllo di riuso del token richiede una ricerca su un digest di dimensione fissa in $SpentTokensDB$. La verificabilità individuale basata su Merkle Tree richiede prove di dimensione logaritmica rispetto al numero di schede pubblicate. La soluzione evita inoltre blockchain pubbliche o protocolli di consenso distribuito, che aumenterebbero complessità, latenza e costo computazionale.

1.6 Analisi rispetto agli avversari del modello

1.6.1 Elettore malevolo

Un elettore malevolo può tentare di votare più volte, riutilizzare un token, presentare una scheda non valida o ripudiare il proprio voto. Il protocollo mitiga il voto multiplo tramite $IssuedTokensDB$ e $SpentTokensDB$. La verifica della firma della GA sul token e della firma σ_U^{Ballot} impedisce l'uso di token non validi o non associati alla chiave dell'elettore.

Un elettore può comunque tentare di mostrare a terzi elementi della propria sessione di voto. La ricevuta di inclusione non contiene la preferenza, ma il protocollo non garantisce piena resistenza alla coercizione in un contesto remoto non presidiato.

1.6.2 Voting Server malevolo

Un Voting Server malevolo potrebbe tentare di rifiutare schede valide, accettare schede duplicate, modificare schede cifrate o non inoltrarle al Registro Elettorale. La modifica

delle schede o dei messaggi verso il Registro è mitigata tramite firme e verifica del Registro Elettorale. Il controllo *pending/committed* riduce il rischio di incoerenza tra token consumati e schede pubblicate.

Il Voting Server resta però una componente critica per la disponibilità e può causare denial-of-service rifiutando richieste legittime. Questo rischio non viene eliminato crittograficamente dal protocollo.

1.6.3 Registro Elettorale malevolo

Un Registro Elettorale malevolo potrebbe tentare di omettere, modificare o riordinare record. La struttura append-only e la radice Merkle firmata rendono rilevabili modifiche successive alla pubblicazione finale. Le ricevute firmate permettono agli elettori di contestare l'eventuale mancata inclusione della propria scheda.

Il Registro conserva comunque un ruolo importante: se rifiuta di pubblicare record o non rende disponibile il Bulletin Board finale, si produce un problema di disponibilità e trasparenza che deve essere trattato come rischio residuo.

1.6.4 Government Authority malevola o compromessa

La Government Authority è una componente ad alta fiducia, perché autentica gli elettori, verifica l'idoneità, firma token, certificati, parametri pubblici e CRL. Una GA malevola potrebbe rilasciare token indebiti, negare autorizzazioni legittime, revocare certificati in modo scorretto o conservare log utili alla correlazione.

Il protocollo riduce la capacità della GA di conoscere la preferenza, perché non riceve la scheda cifrata e non partecipa allo scrutinio. Tuttavia, non può eliminare completamente il rischio derivante da una GA malevola, che resta un'assunzione di fiducia esplicita.

1.6.5 Scrutiny Authority collusa o compromessa

La Scrutiny Authority decifra le schede solo dopo la chiusura delle urne. Nel protocollo base, la distribuzione della SA non viene modellata come threshold decryption matematica, ma come procedura di custodia e autorizzazione congiunta dell'uso di sk_{SA}.

Se meno di k nodi cooperano, lo scrutinio non dovrebbe essere autorizzato. Se almeno k nodi colludono o se la procedura di custodia di sk_{SA} viene aggirata, la protezione offerta dalla distribuzione non è sufficiente. Questo rischio deve essere dichiarato chiaramente: la soglia $\langle k, n \rangle$ riduce il singolo punto di fiducia operativo, ma non fornisce una garanzia crittografica equivalente a una vera threshold cryptography.

1.6.6 Voting Client compromesso

Il Voting Client è una delle principali fonti di rischio residuo. Un client compromesso può modificare la preferenza prima della cifratura, mostrare opzioni false, conservare dati locali o comunicare la scelta a terzi.

Il protocollo mitiga questo rischio tramite distribuzione ufficiale del client, verifica della firma del pacchetto applicativo, canali sicuri e verificabilità di inclusione. Tuttavia,

non può garantire che la preferenza cifrata corrisponda a quella effettivamente voluta dall'elettore.

1.6.7 Avversario di rete

Un avversario di rete può osservare, intercettare, modificare o riprodurre messaggi. Il protocollo mitiga questi attacchi tramite canali sicuri autenticati, certificati, verifica CRL, nonce, timestamp e firme sui messaggi rilevanti.

I replay vengono mitigati tramite valori freschi e controllo di stato, in particolare sul token di voto. Rimangono possibili attacchi di disponibilità, come blocco delle comunicazioni o ritardi artificiali, che non vengono risolti dalla sola crittografia.

1.7 Compromessi progettuali

Il protocollo adotta alcuni compromessi espliciti. Tali compromessi non rappresentano errori della soluzione, ma scelte motivate rispetto agli obiettivi della traccia e agli strumenti trattati nel corso.

Scelta	**Motivazione**	**Rischio residuo**
Referendum binario	Riduce complessità della scheda e dello scrutinio.	Minore generalità rispetto a elezioni complesse.
Nessuna sostituzione del voto	Mantiene semplice l'unicità del token e riduce ambiguità nello scrutinio.	L'elettore non può correggere un voto inviato.
Pubblicazione delle preferenze decifrate validate	Rafforza la verificabilità universale del conteggio.	Possibile correlazione con ordine o timestamp dei record.
Custodia distribuita non-threshold di sk_{SA}	Evita primitive avanzate non trattate come soluzione principale.	Non offre garanzia matematica di threshold decryption.
Nessuna blockchain pubblica	Riduce complessità, latenza e overengineering.	La trasparenza dipende dal Bulletin Board e dalle firme pubblicate.
Nessuna mixnet	Mantiene il protocollo aderente agli strumenti del corso.	Resta rischio residuo di correlazione temporale.

1.8 Rischi residui

I principali rischi residui sono i seguenti:

- compromissione del Voting Client o del dispositivo dell'elettore;
- collusione tra più entità infrastrutturali, in particolare tra GA, VS, ER e SA;
- uso improprio o compromissione della chiave privata di scrutinio sk_{SA};
- correlazione tramite log temporali, indirizzi di rete o ordine dei record pubblicati;

- attacchi alla disponibilità di GA, VS, ER o canali di comunicazione;
- revoche non disponibili o CRL non aggiornate;
- assenza di una piena resistenza alla coercizione nel voto remoto non presidiato.

Questi rischi non invalidano il protocollo, ma delimitano il livello di sicurezza effettivamente raggiunto. La soluzione proposta mira a un compromesso ragionevole tra sicurezza, verificabilità, efficienza e semplicità progettuale, senza introdurre primitive avanzate non necessarie rispetto agli obiettivi del project work.

1.9 Possibili estensioni future non adottate

Alcune estensioni potrebbero migliorare specifiche proprietà del sistema, ma non vengono adottate come parte principale del protocollo per evitare overengineering e mantenere coerenza con gli strumenti trattati nel corso.

- **Threshold decryption crittografica:** migliorerebbe la protezione della chiave di scrutinio, ma richiederebbe una costruzione specifica come threshold RSA o threshold ElGamal.
- **Mixnet:** ridurrebbe il rischio di correlazione tra ordine di arrivo e ordine di scrutinio, ma aumenterebbe la complessità del protocollo.
- **Cifratura omomorfa:** permetterebbe di calcolare il risultato senza decifrare singole schede, ma introduce primitive più avanzate.
- **Blockchain pubblica:** potrebbe aumentare la trasparenza del registro, ma introdurrebbe costi, latenza e problemi di governance non necessari per il modello scelto.
- **Voto sostituibile:** potrebbe mitigare coercizione e errori dell'elettore, ma complicherebbe la gestione di token, versioni della scheda e verificabilità.

1.10 Conclusione dell'analisi

L'analisi mostra che il protocollo supporta in modo più solido autenticità, unicità, integrità e verificabilità di inclusione. Segretezza e pseudoanonimato sono mitigati tramite cifratura, separazione delle responsabilità e mancata pubblicazione dei token, ma restano dipendenti dalle assunzioni su client, Scrutiny Authority e assenza di collusione estesa.

La verificabilità universale può essere resa più forte pubblicando nel *TallyBoard* le preferenze decifrate e validate, collegate ai record finali. Questa scelta rende il conteggio controllabile pubblicamente, ma deve essere accompagnata dalla dichiarazione del rischio residuo di correlazione.

Il protocollo non garantisce pienamente coercion-resistance, disponibilità o anonimato perfetto. Tali limiti sono coerenti con l'obiettivo del progetto: costruire una soluzione ragionevole, efficiente e difendibile, dichiarando con precisione assunzioni e rischi residui.